Joshua McKnight

# Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each control, including the type and purpose, refer to the control categories document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

**Controls assessment checklist**

| Yes | No | Control |
|---|---|---|
| ☐ | ☑ | Least Privilege |
| ☐ | ☑ | Disaster recovery plans |
| ☐ | ☑ | Password policies |
| ☐ | ☑ | Separation of duties |
| ☑ | ☐ | Firewall |
| ☐ | ☑ | Intrusion detection system (IDS) |
| ☐ | ☑ | Backups |
| ☑ | ☐ | Antivirus software |
| ☐ | ☑ | Manual monitoring, maintenance, and intervention for legacy systems |
| ☐ | ☑ | Encryption |
| ☐ | ☑ | Password management system |

| | | |
|---|---|---|
| ☑ | ☐ | Locks (offices, storefront, warehouse) |
| ☑ | ☐ | Closed-circuit television (CCTV) surveillance |
| ☑ | ☐ | Fire detection/prevention (fire alarm, sprinkler system, etc.) |

---

To complete the compliance checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each compliance regulation, review the controls, frameworks, and compliance reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

**Compliance checklist**

Payment Card Industry Data Security Standard (PCI DSS)

| Yes | No | Best practice |
|---|---|---|
| ☐ | ☑ | Only authorized users have access to customers’ credit card information. |
| ☐ | ☑ | Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. |
| ☐ | ☑ | Implement data encryption procedures to better secure credit card transaction touchpoints and data. |
| ☐ | ☑ | Adopt secure password management policies. |

General Data Protection Regulation (GDPR)

| Yes | No | Best practice |
|---|---|---|
| ☐ | ☑ | E.U. customers’ data is kept private/secured. |

| | | |
|---|---|---|
| ☐ | ☑ | There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. |
| ☑ | ☑ | Ensure data is properly classified and inventoried. |
| ☑ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |

System and Organizations Controls (SOC type 1, SOC type 2)

| Yes | No | Best practice |
|---|---|---|
| ☐ | ☑ | User access policies are established. |
| ☐ | ☑ | Sensitive data (PII/SPII) is confidential/private. |
| ☑ | ☐ | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| ☐ | ☑ | Data is available to individuals authorized to access it. |

---

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

**Recommendations (optional):** In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

The 8/10 risk rating reflects significant gaps in access control, encryption, and recovery capabilities. The core places to start are preventative measures to secure current data while rebuilding the security of the company. This includes enforcing an

encryption standard on customer data at rest and in transit to protect confidentiality and reduce the risk of unauthorized disclosure, loss of customer trust, and potential legal consequences. The company must also inventory its assets and classify its data so the IT department can identify sensitive information and prioritize protection of critical systems.

Password policy and protocol is also highly important as without any type of central password system, productivity will continue to decrease as well as a higher threat of passwords being discovered and used maliciously to steal customer PII.

Moving onto administrative controls, it is a necessity that least privilege is established immediately to restrict access to cardholder data and PII based on job responsibilities. Separation of duties should also be established to divide sensitive responsibilities and reduce the risk of misuse. This also encompasses assigning a division to create a disaster recovery plan if a future attack were to occur. This recovery plan must rely on some key components to monitor the attack in real time. A separate division should be implemented to monitor and review programs such as Intrusion Detection systems. The latter group will also work with the current firewalls and update them to run hand in hand to prevent and detect active attacks. Antivirus software and encryption standards will also fall under this concept so modifying these softwares and processes to be up to date and compatible with the IDS.

Finally, there must be a schedule established to create and test backups, monitor and maintain legacy systems, and review password policies and systems. Each of these previously stated tasks should follow the SMART goal format. Each task that currently received a NO on the checklist should have a specific date to be completed by, a specific security goal that it is aiming to correct or achieve, a log of actions taken to ensure the correct policies were enforced when creating/updating these security measures, and an action plan written then reviewed by others within the security team to make sure future actions taken will achieve the desired goal. With these goals in

place, the company can reduce the identified risks and verify that its security measures are effective.